DOC-06: Política de Seguridad de la Información y Gestión de Credenciales (ISO/IEC 27002)

Categoría: Políticas y Seguridad

Origen: Departamento de TI — Mesa de Ayuda TI — Estándar Operativo PYME

Vigencia: 2026 (Estándar Internacional ISO/IEC 27002:2022)

URL: https://soporte.pyme-estandar.org/manuales/DOC-06_politica_seguridad_iso27002.md

Descripción General

Directrices obligatorias de seguridad de la información para los colaboradores de la empresa (entorno corporativo PYME), enfocadas en la protección de activos digitales, confidencialidad de credenciales y prevención de accesos no autorizados.

Procedimiento Operativo Paso a Paso

Paso 1: Requisitos de Complejidad de Contraseñas

1. Toda contraseña corporativa debe tener una longitud mínima de 12 caracteres.

2. Debe combinar al menos 3 de los 4 grupos: mayúsculas (A-Z), minúsculas (a-z), números (0-9) y caracteres especiales (!, @, #, $, %).

3. Se prohíbe el uso de palabras del diccionario, secuencias obvias (123456) o nombres de la empresa.

Paso 2: Prohibición Expresa de Compartir o Revelar Claves

1. Ningún colaborador debe revelar su contraseña a compañeros, jefes o personal externo bajo ninguna circunstancia.

2. Queda estrictamente prohibido anotar contraseñas en notas adhesivas (Post-its) visibles en pantallas o debajo de teclados.

3. El técnico de TI nunca solicitará su contraseña por teléfono, correo ni sistema de tickets.

Paso 3: Bloqueo Automático de Pantalla y Puesto Limpio

1. Al levantarse de su puesto de trabajo, el colaborador debe pulsar inmediatamente las teclas Win + L para bloquear la sesión.

2. La directiva corporativa bloquea automáticamente las estaciones de trabajo tras 5 minutos de inactividad continua.

3. Se aplica la política de «escritorio limpio»: no dejar documentos confidenciales de clientes impresos en bandejas de salida.

Paso 4: Protocolo de Alerta Temprana ante Sospecha de Phishing

1. Si recibe un correo electrónico sospechoso solicitando verificar contraseñas, bancario o con enlaces extraños, no haga clic.

2. Reenvíe el mensaje como archivo adjunto a seguridad-ti@empresa.com.

3. El técnico de TI evaluará el remitente y bloqueará el dominio malicioso en el firewall perimetral.